

Project Report: Penetration Testing Tool

Prepared by

Himanshu Gurjar (2023BTECH036)
Ayush Choudhary (2023BTECH020)
Divyansh Thakur (2023BTECH026)
Sarvesh Gulgulia (2023BTECH073)

Under the guidance of
Prof. Devendra Bhavsar

Submitted in
partial fulfilment of the requirements
for the course of

Introduction to Cyber Security (CS1233)



Institute of Engineering & Technology (IET)
JK Lakshmipat University
(November 2025)

CERTIFICATE

This is to certify that the project report titled "Penetration Testing Tool" is a bona fide work completed by Himanshu Gurjar (2023BTECH036), Ayush Choudhary(2023BTECH020), Divyansh Thakur (2023BTECH026), Sarvesh Gulgulia (2023BTECH073). The report is submitted in partial fulfilment of the requirements for the course of **Introduction to Cyber Security (CS1233)** under the guidance of **Prof. Devendra Bhavsar**. This project demonstrates the understanding and application of advanced cyber security principles, network scanning, web vulnerability detection, and ethical reporting practices. We confirm that the work presented in this report is original and has not been copied or submitted elsewhere for the award of any degree or diploma.

Submitted By:

Himanshu Gurjar (2023BTECH036)

Ayush Choudhary (2023BTECH020)

Divyansh Thakur (2023BTECH026)

Sarvesh Gulgulia (2023BTECH073)

Date: 25/11/2025

Verified By:

Devendra Bhavsar

Professor, Institute of engineering and technology

Signature: _____

ACKNOWLEDGMENT

We extend our heartfelt gratitude to everyone who supported and guided us throughout the development of this project, Penetration Testing Tool.

We sincerely thank our mentor and faculty member, Prof. Devendra Bhavsar , for their invaluable advice, constructive feedback, and encouragement, which played a significant role in shaping this project. Their expertise and guidance helped us overcome challenges and refine our work.

We are also grateful to our teammates for their dedication, teamwork, and perseverance in completing this project. The collaborative effort, mutual support, and shared knowledge made this journey both productive and enjoyable.

Finally, we would like to acknowledge the role of various open-source resources, tools, and platforms, including Python 3, libraries like requests and BeautifulSoup4, and the ethical testing platforms such as DVWA and OWASP Juice Shop. Their documentation and frameworks significantly contributed to our learning and implementation process.

This project has been a remarkable learning experience, and we thank everyone who contributed to its successful completion.

TABLE OF CONTENTS

<i>Certificate</i>	<i>i</i>
<i>Acknowledgement</i>	<i>ii</i>
<i>Table of contents</i>	<i>iii</i>
1. Introduction	01
2. Objective	02
3. Approach	04
4. Phases of development	05
5. Difficulties faced	09
6. Conclusion	10

1. INTRODUCTION: -

In today's highly digitized world, the security of web applications is a critical concern, with data breaches and unauthorized access posing significant threats. This project addresses the essential need for proactive security measures by developing a Python-based vulnerability scanner designed to automate key phases of a penetration test.

Project Overview

This tool is a proof-of-concept that integrates multiple security testing capabilities into a single, cohesive application, often referred to as Mini-Nmap + Mini-SQLMap. The tool performs an end-to-end penetration test workflow: Reconnaissance, Scanning, Detection, an optional Proof-of-Concept (PoC), and Reporting.

Ethical Scope

Crucially, this tool is intended strictly for educational purposes and must only be run against isolated, controlled lab environments such as DVWA, OWASP Juice Shop, or Metasploitable2. This adherence to ethical guidelines ensures that the project remains a safe, educational exercise in vulnerability assessment and reporting. The tool stands as a testament to bridging theoretical cyber security principles with practical, ethical system development.

2. OBJECTIVE: -

The primary objectives of the Penetration Testing Tool project were carefully designed to address the challenges of simulated security testing within an ethical, educational framework.

A. Core Workflow Objectives

1. **End-to-End Automation:** To implement an integrated, automated workflow that systematically executes the five core phases of a penetration test: Reconnaissance → Scanning → Detection → (Optional) Proof-of-Concept → Reporting.
2. **Original Logic Implementation:** To develop fundamental logic for discovery, network scanning, and vulnerability detection (SQLi and XSS) using original Python code, without relying solely on external tools.
3. **Reporting Automation:** To automatically generate a professional, comprehensive PDF/HTML report detailing findings, evidence, severity scoring (CVSS-like), and clear, actionable remediation advice.

B. Technical and Module-Specific Objectives

1. **Web Discovery:** To build a Crawler module capable of enumerating URLs, links, and extracting input forms/parameters from the target application using Python libraries like requests and BeautifulSoup4.
2. **Network Discovery:** To implement a multi-threaded Port Scanner module using the socket library to efficiently identify open TCP ports within a user-defined range and capture initial service banners (mini-Nmap behavior).
3. **Active Detection:** To implement conservative, non-destructive test cases for:
 - SQL Injection (SQLi): Utilizing error-based and boolean-difference checks.
 - Cross-Site Scripting (XSS): Employing unique marker tokens to detect unescaped reflection in the response.
4. **Passive Analysis:** To integrate checks for common security misconfigurations, including the presence of required security headers (e.g., HSTS, CSP) and insecure cookie attributes.

C. Ethical and Scope Objectives

1. **Controlled Environment Focus:** To ensure the tool's usage is strictly limited to isolated, controlled lab environments (such as DVWA, OWASP Juice Shop, Metasploitable2) to adhere to ethical hacking protocols.
2. **Safe PoC Implementation:** To develop the Exploit/PoC Module with mandatory user confirmation and an allowlist to ensure Proof-of-Concept demonstrations (e.g., time-based SQLi, harmless XSS alerts) are non-destructive and only run under explicit authorization.

3. APPROACH: -

Workflow Model

The entire project is conceptualized and built around implementing and linking the following ethical hacking phases in a continuous chain:

1. **Reconnaissance (Recon):** This initial step involves automatic crawling, form/parameter extraction, and endpoint enumeration.
2. **Scanning:** This phase performs two key functions: lightweight network discovery (port and banner scanning) and passive web checks (security headers).
3. **Detection:** This is the active testing phase, running non-destructive checks for vulnerabilities like SQL Injection and XSS.
4. **(Optional) Proof-of-Concept (PoC):** This module provides single-shot demonstrations of impact, strictly enabled only with explicit user confirmation and an allowlist in the lab environment.
5. **Reporting:** The final step involves generating a professional, automated report (PDF/HTML) that summarizes findings, evidence, and remediation suggestions.

4. PHASES OF DEVELOPMENT: -

Week 1: Requirements and Setup

We initiated the project by defining detailed requirements, establishing the core project configuration, and ensuring the isolated lab environment was properly set up. This included configuring the attacker machine (Kali Linux)



Week 2: Discovery Module Implementation

The focus shifted to the Reconnaissance phase by implementing the Crawler module. This involved setting up HTTP interaction using the requests library for parsing HTML to find URLs, links, and forms for parameter extraction.

Penetration Testing Suite

Comprehensive Web Application Security Scanner

New Scan Configuration

Target URL

http://example.com or https://example.com

Crawl Depth

2

Start Port

1

End Port

1024

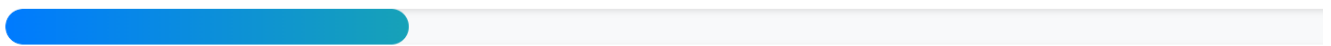
☐ Run PoC Module (Proof of Concept)

▶ Start Scan

Week 3: Network Scanning Implementation

We developed the Port Scanner module (mini-Nmap behavior). This utilized the Python socket library for low-level TCP connect() checks for common ports, along with implementing banner grabbing functionality.

Scan Progress



30%

Crawling

Port Scanning

Passive Scanning

Active Scanning

Reporting

[10:58:19 pm] Initializing scan...

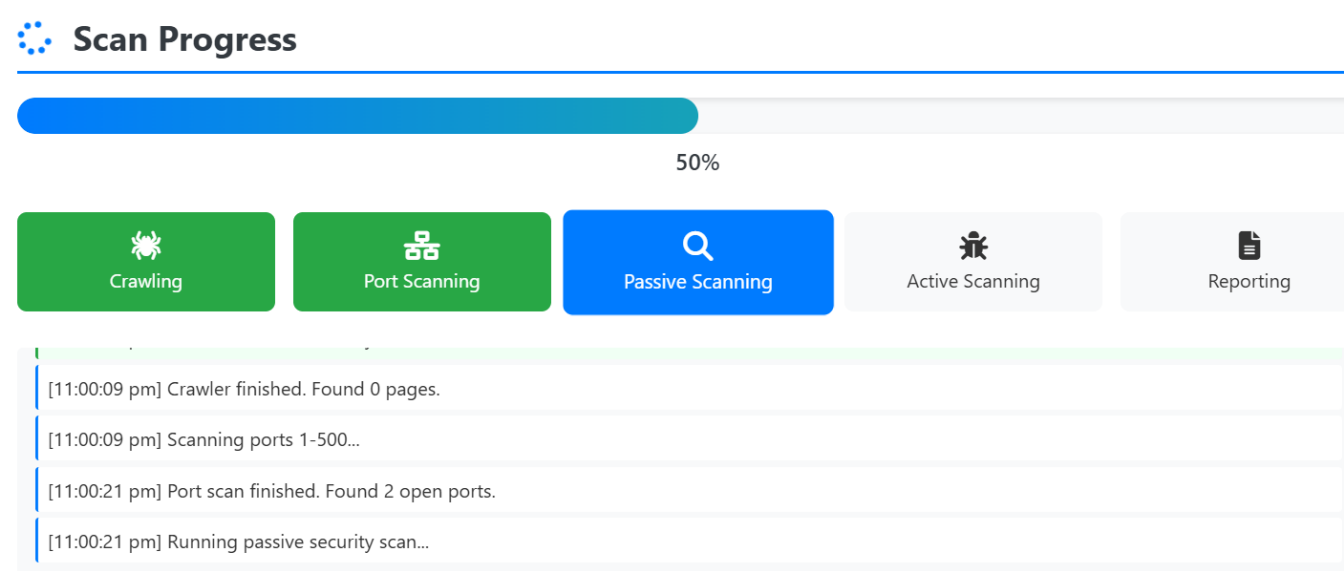
[10:58:19 pm] Scan started successfully! ID: scan_1763832499_42cbb7a1

[10:58:19 pm] Crawler finished. Found 1 pages.

[10:58:19 pm] Scanning ports 1-500...

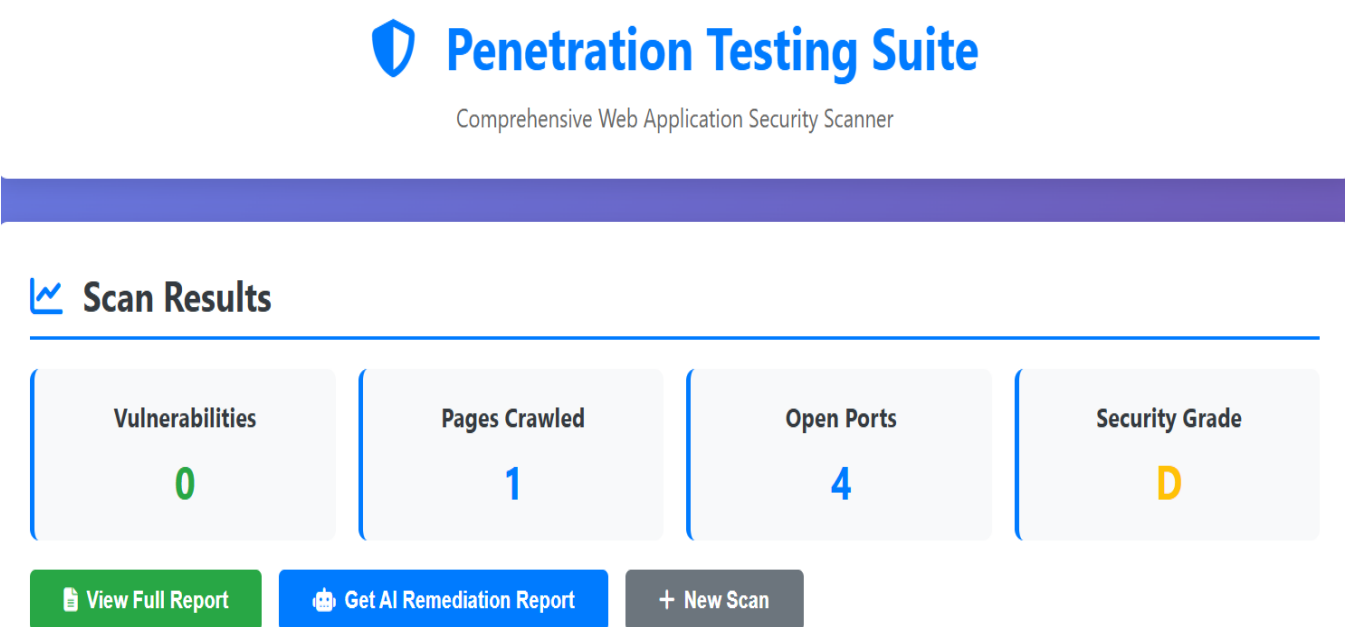
Week 4: Passive Analysis Implementation

This week was dedicated to passive checks. We implemented the **Passive Analyzer** to inspect HTTP responses for crucial security headers (like HSTS and CSP) and to check for common exposed paths



Week 6: Exploit/PoC Module Development

To demonstrate impact ethically, we implemented the **Exploit/PoC Module**. This module was designed with strict constraints, requiring **explicit confirmation** and adherence to a **safe allowlist** to ensure non-destructive demonstrations only occurred in the lab.



Week 7: Reporting and Integration

The focus was on the final output. We developed the **Reporter module**, integrating libraries like reportlab or fpdf to generate the final **PDF/HTML report**. All preceding modules were connected to feed their findings into this centralized reporting engine. And we also added an Api through which this report was taken to Gemini Ai and it provided with the remediations and what practices the sites should use.

Penetration Test Report

Target: <https://httpbin.org>

Scan Date: 2025-11-23T16:59:46.834269

Scan Summary

Overall Grade

C

Active Vulnerabilities

13

Open Ports

2

Finding: Average security posture. Key areas need attention.

Active Vulnerabilities (SQLi, XSS)

XSS (Reflected, simple)

<https://httpbin.org/post+>

XSS (Reflected, simple)

<https://httpbin.org/post+>

Port Scan Results

Port	Protocol	Status	Banner/Service
80	HTTP	open	HTTP/200 gunicorn/19.9.0
443	HTTP	open	HTTP/200 gunicorn/19.9.0

Full Scan Data (JSON)

View Raw JSON Output

```
{
  "target_url": "https://httpbin.org",
  "scan_start_time": "2025-11-23T16:59:46.834269",
  "crawl_results": {
    "pages": [
      {
        "url": "https://httpbin.org",
        "status": 200,
        "title": "httpbin.org",
        "links": [
          {
            "url": "https://httpbin.org/forms/post",
            "text": "HTML form"
          }
        ],
        "forms": []
      },
      {
        "url": "https://httpbin.org/forms/post",
        "status": 200,
        "title": "No title",
        "links": [],
        "forms": [
          {
            "action": "https://httpbin.org/post",
            "method": "post",

```

AI-Powered Remediation Report

Powered by GEMINI

Total Vulnerabilities

19

Critical

19

Medium

0

Low

0

Active Vulnerabilities

1. XSS (Reflected, simple)

High

Priority: High

URL: <https://httpbin.org/post>
Parameter: custname
Method: POST

Remediation

Investigate and remediate XSS (Reflected, simple) vulnerability. Review OWASP guidelines for best practices.

- Review the vulnerability details and evidence
- Consult OWASP Top 10 guidelines
- Implement input validation and output encoding
- Test the fix thoroughly before deploying
- Consider security code review and penetration testing

Week 8: Testing

The final week was dedicated to comprehensive testing across all targeted lab environments, final quality assurance, completing the required documentation, and preparing the final demonstration

```
OUTPUT  PROBLEMS  DEBUG CONSOLE  TERMINAL  PORTS
python3.12 - pentest

PS D:\academics\CYBER\pentest_project1\pentest_project> python app.py
2025-11-22 22:54:40,993 [INFO] - 127.0.0.1 - - [22/Nov/2025 22:54:40] "GET /api/scan/scan_1763832262_09addac7/status HTTP/1.1" 200 -
2025-11-22 22:54:43,824 [INFO] - 127.0.0.1 - - [22/Nov/2025 22:54:43] "GET /api/scan/scan_1763832262_09addac7/status HTTP/1.1" 200 -
2025-11-22 22:54:46,821 [INFO] - 127.0.0.1 - - [22/Nov/2025 22:54:46] "GET /api/scan/scan_1763832262_09addac7/status HTTP/1.1" 200 -
2025-11-22 22:54:49,818 [INFO] - 127.0.0.1 - - [22/Nov/2025 22:54:49] "GET /api/scan/scan_1763832262_09addac7/status HTTP/1.1" 200 -
2025-11-22 22:54:50,821 [INFO] - 127.0.0.1 - - [22/Nov/2025 22:54:50] "GET /api/scans HTTP/1.1" 200 -
2025-11-22 22:54:51,478 [INFO] - [Crawler] (Depth 1) Visiting: https://www.youtube.com/about/press/
2025-11-22 22:54:52,819 [INFO] - 127.0.0.1 - - [22/Nov/2025 22:54:52] "GET /api/scan/scan_1763832262_09addac7/status HTTP/1.1" 200 -
2025-11-22 22:54:55,818 [INFO] - 127.0.0.1 - - [22/Nov/2025 22:54:55] "GET /api/scan/scan_1763832262_09addac7/status HTTP/1.1" 200 -
2025-11-22 22:54:58,819 [INFO] - 127.0.0.1 - - [22/Nov/2025 22:54:58] "GET /api/scan/scan_1763832262_09addac7/status HTTP/1.1" 200 -
2025-11-22 22:55:00,813 [INFO] - 127.0.0.1 - - [22/Nov/2025 22:55:00] "GET /api/scans HTTP/1.1" 200 -
2025-11-22 22:55:01,817 [INFO] - 127.0.0.1 - - [22/Nov/2025 22:55:01] "GET /api/scan/scan_1763832262_09addac7/status HTTP/1.1" 200 -
2025-11-22 22:55:04,811 [INFO] - 127.0.0.1 - - [22/Nov/2025 22:55:04] "GET /api/scan/scan_1763832262_09addac7/status HTTP/1.1" 200 -
```

5. **DIFFICULTIES FACED:** -

1. **Ethical Constraints and Detection Logic:** The main technical challenge was creating effective Active Detection Logic (for SQLi and XSS) that was strictly non-destructive. This required complex tuning to rely on indirect evidence like error-based strings and boolean-difference checks instead of relying on harmful execution methods.
2. **Module Integration and Concurrency:** Integrating low-level tools (like the socket-based Port Scanner) with web-based tools (like the Crawler) while ensuring seamless data flow to the final Reporter was difficult. Managing concurrency using `concurrent.futures` for the Port Scanner required careful design to maintain speed and stability.
3. **Proof-of-Concept (PoC) Safety:** Designing the optional Exploit/PoC Module necessitated strict controls to guarantee it remained lab-only and non-destructive. This involved implementing both explicit user confirmation and a strict allowlist to prevent any accidental misuse.

6. CONCLUSION:

The journey of developing the Penetration Testing Tool (Mini-Nmap + Mini-SQLMap) has been a testament to our dedication, teamwork, and problem-solving skills. Starting with the core objective of building an integrated scanner, we successfully expanded its capabilities by implementing an end-to-end workflow: Recon → Scan → Detect → (Optional) PoC → Report.

Key Achievements

- **Integrated Functionality:** We successfully integrated discovery (crawling), network scanning (port and banner grabbing), and active detection (SQLi and XSS) into a single, cohesive application.
- **Ethical Safety:** The tool maintains robust security by strictly adhering to the lab-only policy and implementing the Safe PoC Module with explicit confirmation flows to guarantee non-destructive operation.
- **Professional Output:** The project culminates in generating professional reports (PDF/HTML) that summarize findings, evidence, and clear remediation guidance.

Project Significance

The final product, the Penetration Testing Tool, represents a culmination of our efforts—a secure, scalable, and functional application. It stands as a proof of concept for secure digital communication and automated security analysis, showcasing its potential to contribute meaningfully to the evolving landscape of cybersecurity and penetration testing methodologies.

